
CYBERSECURITY FOR PROFESSIONALS BOOTCAMP

INDIVIDUAL LAB

Triaging SIEM Alerts and Simulating Incident Response

Week 7 - Day 1 - Individual Lab

No software to install • No accounts to create • No cost

1. Before You Start

This lab runs on paper and in a spreadsheet. There is no system to log into, no console to learn, and no password to request. Everything you need is printed in this document.

That is deliberate. Tier 1 triage is a judgement skill, not a tool skill. You will learn the SIEM console itself in Week 8. Today is about whether you can look at an alert and make a call you can defend.

1.1 What you need

Item	Detail
A spreadsheet	Excel, Google Sheets or LibreOffice Calc. Your triage log lives here.
A document editor	
A calculator	Your phone is fine. You will do distance and time arithmetic on the impossible-travel alerts.
This document	Keep it open. Sections 4 and 5 are reference material you will use constantly.

There are no trick questions, but there are hard ones

Twenty alerts are in the queue. Roughly half should be closed and roughly half escalated, which is close to what a real Tier 1 shift looks like.

Two of them are genuinely ambiguous. Reasonable analysts could disagree. Those are not mistakes in the lab - they are the point of it, and how you handle them is worth more marks than the easy calls.

Several alerts look alarming and are benign. Several look routine and are not. Read the reference data in Section 4 before you judge anything.

1.2 Scope and ethics

Read this before you start

Every alert, log line, email address, account and transaction in this document is fabricated for the exercise. Meridian Trust Bank does not exist.

The external addresses and domains in the queue belong to the scenario. Do not visit them, look them up in a service that connects to them, or paste them into any site that performs live lookups.

Do not run any scanning or lookup tool against anything, anywhere, as part of this lab. There is nothing here that requires it.

2. The Scenario

You are a Tier 1 security analyst in Meridian Trust Bank's Security Operations Centre. It is Wednesday morning. The overnight queue has not been worked because the night analyst was pulled onto a separate incident, so twenty alerts are waiting for you.

Your shift lead wants the queue cleared by end of day, with a decision and a justification on every single alert.

2.1 How a tiered SOC works

Tier	What they do	What they hand on
Tier 1 - Monitoring and Triage	Works the alert queue. Applies runbooks. Decides close or escalate. Does not investigate deeply and does not take remediation action.	An escalation note to Tier 2, or a documented closure.
Tier 2 - Investigation	Takes escalations and investigates properly: pulls more data, correlates across systems, confirms or disproves the Tier 1 suspicion.	A confirmed incident to Tier 3, or a closed investigation.
Tier 3 - Hunt and Incident Response	Runs full incident response, hunts for related activity, coordinates containment and remediation.	A resolved incident and an after-action report.

The two ways a Tier 1 analyst fails

Escalating everything. If you escalate all twenty alerts, Tier 2 drowns and stops trusting your judgement. The queue exists precisely so that somebody filters it.

Closing something real. A single wrongly closed alert can be the one that mattered, and nobody will ever know it was wrong until the incident surfaces weeks later.

The job is holding both of those in mind at once. Your justification is what protects you either way - a closure with sound recorded reasoning is defensible even when it later turns out to be wrong.

3. How to Work Through This Lab

3.1 Time plan

Session	Section	What you are doing	Guide time
Day 1	4	Read the reference data before you touch the queue	30 minutes
Day 1	5	Read the four runbooks	45 minutes
Day 1	6	Work the twenty-alert queue	3 to 4 hours
Day 1	7	Write your escalation notes	1 hour

3.2 Set up your triage log first

Create a spreadsheet with these columns before you read a single alert. Working the queue without a log is how analysts lose track of what they have already decided.

Column	What goes in it
Alert ID	MTB-A01 through MTB-D05
Type	Failed login, impossible travel, BEC indicator, or wire transfer
Decision	CLOSE or ESCALATE
Confidence	High, medium or low. Be honest.
Justification	Why. One or two sentences citing the specific detail that decided it.
Runbook step	Which runbook criterion you applied
Linked alerts	Any other alert in the queue you think is related

The Linked alerts column is the one people skip

Alerts arrive one at a time, in separate categories, often hours apart. Attacks do not.

Fill that column in as you go. If you finish the queue and it is completely empty, go back and look again.

3.3 What a good justification looks like

Standard	Example
Not acceptable	Looks fine. Closing.
Passing	Closing. The failed logins came from the user's own corporate IP and succeeded on the eighth attempt, which looks like a forgotten password.
Strong	Closing with high confidence. Seven failures then a success for cwalsh, all from 10.50.1.31, which the directory in Section 4.2 confirms is her assigned workstation. The sequence ran 08:41 to 08:44 on a Tuesday, inside business hours. The quarterly password rotation completed the previous day per Section 4.5, which makes a forgotten password the most likely explanation. Failed Login Runbook closure criterion 2 applies. No escalation, but I have noted it in case the same account appears again this week.

The pattern to copy

State the decision and your confidence. Name the specific evidence and where you got it. Say what ordinary explanation fits. Cite the runbook criterion. Note anything that would change your mind.

Five sentences. Every alert in your log should read like that.

4. Reference Data

Read this section before you work the queue. Most of the alerts cannot be decided correctly without it, and several look completely different once you have.

4.1 Meridian Trust at a glance

Item	Detail
Headquarters	Pittsburgh, Pennsylvania. All offices are in the Pittsburgh metro area.
Business hours	07:00 to 19:00 Eastern, Monday to Friday. Treasury Operations runs 07:00 to 17:00.
Wire cut-off	17:00 Eastern. Wires initiated after cut-off queue for the next business day.
Dual approval	Any outbound wire over 25,000 US dollars requires a second approver.
Today	Wednesday. The queue covers Monday night through this morning.

4.2 Staff directory (extract)

Account	Name and role	Assigned workstation	Notes
cwalsh	Carla Walsh, Retail Operations	10.50.1.31	-
dkoenig	Daniel Koenig, Infrastructure, domain admin	10.50.1.52	On approved leave all week
mnguyen	Minh Nguyen, Branch Support	10.50.1.44	New phone enrolled in MDM on Monday
rpatel	Rhea Patel, Credit Risk	10.50.1.60	-
jhaddad	Joseph Haddad, Commercial Lending	10.50.1.63	Approved travel, Miami conference, Tue to Fri
lbrennan	Liam Brennan, Data Services	10.50.1.71	Remote worker, uses corporate VPN daily
tokafor	Thomas Okafor, Treasury Operations	10.50.1.58	Authorised wire initiator
sgrigsby	Sara Grigsby, Audit	10.50.1.66	-
bfoster	Brian Foster, Marketing	10.50.1.80	-
dkessler	Diane Kessler, Chief Financial Officer	10.50.1.12	-
rharper	Ray Harper, Accounts Payable	10.50.1.49	Authorised payee administrator

4.3 Known network ranges

Range or address	What it is
10.50.1.0/24	Corporate workstation subnet, Pittsburgh offices
10.50.2.0/24	Server subnet
198.51.100.0/24	Meridian Trust corporate VPN egress. Physically located in a Columbus, Ohio datacentre. All remote-worker traffic appears to originate here.

Range or address	What it is
203.0.113.14	Meridian Trust mail gateway outbound address

The VPN egress range is the single most useful fact in this section

A remote worker sitting in their kitchen in Pittsburgh will appear to log in from Columbus, Ohio, because that is where the VPN traffic leaves Meridian Trust's network.

At least one alert in the queue looks like impossible travel purely because of this and is completely benign. Check every geolocation against this range before you escalate it.

4.4 Service accounts

Account	Purpose	Expected source	Expected behaviour
svc-backup-agent	Nightly backup job	10.50.2.25	Authenticates at 02:00 daily
svc-sql	Database service account	10.50.2.25	Authenticates continuously during business hours
svc-monitor	Estate monitoring agent	10.50.2.30	Checks in every 5 minutes

4.5 Recent change record

Date	Change	Reference
Monday	Quarterly password rotation completed for all Retail Operations staff	CHG-8841
Monday	Minh Nguyen issued a replacement phone, enrolled in MDM	CHG-8847
Two weeks ago	Backup agent credential rotated. Application team did not update the job.	CHG-8802, still open
Last Thursday	Payment of 250,000 US dollars to Harrow Logistics approved by CFO and Treasury lead	CR-2291

4.6 Approved wire beneficiaries (extract)

Beneficiary	Bank	First used	Typical amount
ADP Payroll Services	Wells Fargo, US	2019	128,000 to 132,000 US dollars, fortnightly
Harrow Logistics Ltd	Barclays, UK	2021	40,000 to 260,000 US dollars, irregular
Castlereagh Supply Co	PNC Bank, US	2022	80,000 to 95,000 US dollars, monthly
Delacroix Systems	Santander, ES	2023	15,000 to 22,000 US dollars, monthly

4.7 Travel time reference

You will need this for the impossible-travel alerts. Work out the distance, work out how fast the person would have had to move, and compare it against reality.

Mode	Realistic speed
Commercial airliner, cruise	500 to 560 miles per hour
Commercial flight, door to door	Add roughly 2 hours for airport time either side
Car on a motorway	65 to 75 miles per hour
Anything faster than about 600 miles per hour	Not physically possible for a person

Route from Pittsburgh	Great-circle distance
Columbus, Ohio	162 miles
Toronto, Canada	224 miles
Miami, Florida	1,014 miles
Bucharest, Romania	4,998 miles
Lagos, Nigeria	5,578 miles

5. The Runbooks

A runbook is the SOC's documented procedure for one alert type. It exists so that every analyst handles the same alert the same way, and so that a decision can be reviewed later against what the procedure actually said.

Apply them. If you close or escalate against a runbook you must say why, and that is a legitimate thing to do - runbooks do not cover everything. What is not acceptable is ignoring them silently.

5.1 Runbook: Failed Login

What the alert means

One or more authentication failures crossed a threshold. Thresholds are deliberately low, so most of these are benign.

What to check, in order

1. How many failures, over what period, and did any attempt eventually succeed?
2. Is the source address the user's own assigned workstation, the corporate VPN range, or somewhere else entirely?
3. One account or many? Failures spread across many accounts from one source is a different attack entirely.
4. Is the account privileged, a service account, or an ordinary user?
5. Does the timing fit the user's normal working pattern, and is there a change record that explains it?

Close if

- Fewer than 10 failures on a single ordinary account from that user's own workstation or the VPN range, followed by a success, inside business hours.
- A change record explains it, such as a password rotation or a new device enrolment.
- A service account failing from its expected source in its expected pattern, with a known open ticket.

Escalate if

- Failures span multiple accounts from a single source. This is password spraying and the count does not need to be high.
- The account is privileged and the attempt succeeded.
- The source is external or unrecognised.
- The activity falls outside the user's working pattern with no change record, and especially if the user is known to be away.

5.2 Runbook: Impossible Travel

What the alert means

The same account authenticated from two locations too far apart for the person to have travelled between them in the time available. The alert is generated automatically from IP geolocation, which is frequently wrong.

What to check, in order

1. Do the arithmetic yourself. Distance divided by elapsed time gives required speed. Compare against Section 4.7.
2. Is either address in the corporate VPN range? If so the geolocation is an artefact, not a movement.
3. Is there approved travel on record for this user?
4. What did the account do after the second login? A login is only half the story.
5. Was multi-factor authentication satisfied, and how - an approved push, or repeated prompts?

Close if

- The required speed is achievable by commercial flight and there is approved travel on record.
- One of the two addresses belongs to the corporate VPN egress range.
- The two locations are close enough that ordinary ground travel explains the gap.

Escalate if

- The required speed exceeds roughly 600 miles per hour. No person moves that fast.
- The second location is somewhere the user has never logged in from and there is no travel record.
- The account performed sensitive actions immediately after the second login.

5.3 Runbook: Business Email Compromise Indicator

What the alert means

Something in the mail environment matched a pattern associated with business email compromise. BEC is not malware. It is an attacker using a real or convincing mailbox to get money moved, and the technical footprint is very small.

What to check, in order

1. If a mailbox rule was created, what does it actually do? Rules that hide or delete messages are the single strongest BEC indicator there is.
2. Who created the rule, from what address, and at what time?
3. If a domain is involved, compare it character by character against the real one.

4. Does the display name match a real employee while the underlying address does not?
5. Did the message reach anyone, or was it blocked at the gateway?

Close if

- The activity is an ordinary mail feature used ordinarily, such as an out-of-office reply set by a user who is genuinely on leave.
- The message was blocked at the gateway, reached nobody, and the pattern is generic rather than targeted.

Escalate if

- A rule moves, deletes or marks as read any message matching financial keywords. Treat this as compromise until proven otherwise.
- A rule forwards mail to an address outside the bank.
- A lookalike domain is involved, whether or not the message was delivered.
- An executive or an authorised payment initiator is impersonated or targeted.

5.4 Runbook: Suspicious Wire Transfer

What the alert means

An outbound transfer matched a fraud-monitoring rule. Meridian Trust moves large sums legitimately every day, so the amount alone tells you very little.

What to check, in order

1. Is the beneficiary on the approved list in Section 4.6, and is the amount consistent with its history?
2. If the beneficiary is new, when was it added and by whom?
3. If bank details on an existing beneficiary changed, how was the change requested and was it verified out of band?
4. Was it initiated inside business hours by an authorised initiator, and was dual approval satisfied?
5. Are there several transfers that look designed to stay under a threshold?

Close if

- Established beneficiary, amount within its normal range, initiated in hours by an authorised person.
- A change or approval record documents it, with the approvals recorded.

Escalate if

- A new beneficiary receives a significant first payment, particularly outside business hours.
- Bank details on an existing beneficiary changed shortly before a scheduled payment and the request arrived by email.
- Multiple transfers sit just under a reporting or approval threshold.
- The initiating account is the subject of any other alert in the queue.

That last criterion is doing a lot of work

Wire fraud almost never appears as a single wire alert. It appears as a login alert, then a mailbox alert, then a wire alert, hours apart, in three different categories, each one individually explainable.

Cross-check every wire alert against the account names in the rest of your queue before you decide.

6. Day 1: The Alert Queue

Twenty alerts. Work them in any order. Record a decision and a justification for every one.

6.1 Failed login alerts

MTB-A01	FAILED LOGIN THRESHOLD	Tue 08:41 EDT	Severity: Low
Account	: cwalsh		
Source	: 10.50.1.31		
Detail	: 7 consecutive authentication failures 08:41:02 to 08:43:48, followed by a successful authentication at 08:44:11.		
MFA	: Satisfied, approved push, first prompt.		

MTB-A02	FAILED LOGIN THRESHOLD	Tue 23:18 EDT	Severity: Medium
Accounts	: 312 distinct accounts		
Source	: 45.134.26.91 (external, geolocated to Netherlands)		
Detail	: 1,284 authentication failures in an 11 minute window against the external webmail portal. Between 3 and 5 attempts per account. No successful authentications recorded.		
MFA	: Not reached.		

MTB-A03	FAILED LOGIN THRESHOLD	Wed 02:00 EDT	Severity: Low
Account	: svc-backup-agent		
Source	: 10.50.2.25		
Detail	: 4 authentication failures at 02:00:03. No success. This alert has fired at the same time every night for the past 14 nights.		
MFA	: Not applicable, service account.		

MTB-A04	FAILED LOGIN THRESHOLD	Tue 23:47 EDT	Severity: Medium
Account	: dkoenig		
Source	: 10.50.1.77		
Detail	: 9 authentication failures 23:47:19 to 23:51:02, followed by a successful authentication at 23:51:40. Account holds domain administrator privilege.		
MFA	: Satisfied on the fourth push prompt.		

MTB-A05	FAILED LOGIN THRESHOLD	Wed 07:15 EDT	Severity: Low
Account	: mnguyen		
Source	: 198.51.100.22		
Detail	: 3 authentication failures 07:15:44 to 07:16:20, followed by a successful authentication at 07:16:58 from a newly registered mobile device.		
MFA	: Satisfied, approved push, first prompt.		

6.2 Impossible travel alerts

MTB-B01 IMPOSSIBLE TRAVEL Wed 04:01 EDT Severity: High
 Account : rpatel
 Login 1 : Tue 03:14 EDT, 10.50.1.60, Pittsburgh US
 Login 2 : Wed 04:01 EDT, 102.89.44.7, Lagos NG
 Elapsed : 47 minutes
 Post-login: No sensitive system access recorded in the following hour.
 MFA : Satisfied on the sixth push prompt.

MTB-B02 IMPOSSIBLE TRAVEL Tue 10:20 EDT Severity: Medium
 Account : jhaddad
 Login 1 : Tue 06:20 EDT, 10.50.1.63, Pittsburgh US
 Login 2 : Tue 10:20 EDT, 72.44.19.203, Miami US
 Elapsed : 4 hours 0 minutes
 Post-login: Opened the commercial lending pipeline report. Normal for this user.
 MFA : Satisfied, approved push, first prompt.

MTB-B03 IMPOSSIBLE TRAVEL Wed 09:23 EDT Severity: Medium
 Account : lbrennan
 Login 1 : Wed 09:02 EDT, 10.50.1.71, Pittsburgh US
 Login 2 : Wed 09:23 EDT, 198.51.100.41, Columbus US
 Elapsed : 21 minutes
 Post-login: Routine access to data services tooling.
 MFA : Satisfied, approved push, first prompt.

MTB-B04 IMPOSSIBLE TRAVEL Tue 22:58 EDT Severity: High
 Account : tokafor
 Login 1 : Tue 21:50 EDT, 10.50.1.58, Pittsburgh US
 Login 2 : Tue 22:58 EDT, 89.36.216.140, Bucharest RO
 Elapsed : 1 hour 8 minutes
 Post-login: Accessed the wire transfer initiation system at 23:04.
 MFA : Satisfied on the ninth push prompt.

MTB-B05 IMPOSSIBLE TRAVEL Wed 09:15 EDT Severity: Medium
 Account : sgrigsby
 Login 1 : Wed 07:40 EDT, 10.50.1.66, Pittsburgh US
 Login 2 : Wed 09:15 EDT, 99.240.18.66, Toronto CA
 Elapsed : 1 hour 35 minutes
 Post-login: Accessed the internal audit workpaper repository.
 MFA : Satisfied, approved push, first prompt.
 Note : No travel request on file. Audit staff travel is booked departmentally and is not always recorded centrally.

6.3 Business email compromise indicator alerts

MTB-C01 MAILBOX RULE CREATED Tue 23:09 EDT Severity: High
 Mailbox : tokafor
 Created by: tokafor, from 89.36.216.140
 Rule name : ..
 Rule logic: IF subject or body contains any of: wire, invoice, payment, beneficiary, confirm, approval

THEN move to folder 'RSS Subscriptions' AND mark as read

MTB-C02 LOOKALIKE DOMAIN Tue 19:44 EDT Severity: High
 From : t.okafor@meridian-trust.com
 To : tokafor@meridiantrust.com
 Subject : Treasury portal - action required before cut-off
 Detail : Sender domain registered 9 days ago. SPF: fail. DKIM: none.
 DMARC: none. Message contained a link to a credential entry page
 styled as the Meridian Trust treasury portal.
 Gateway : DELIVERED to inbox. Not quarantined.

MTB-C03 EXTERNAL AUTO-REPLY Tue 07:02 EDT Severity: Low
 Mailbox : jhaddad
 Detail : Out-of-office auto-reply enabled for external senders. Text reads:
 'I am at a conference in Miami until Friday. For urgent lending
 matters contact Commercial Lending duty desk.'
 Created by: jhaddad, from 10.50.1.63, Mon 16:50 EDT

MTB-C04 EXTERNAL FORWARDING RULE Tue 14:31 EDT Severity: Medium
 Mailbox : bfoster
 Created by: bfoster, from 10.50.1.80
 Rule name : 'Copy to personal'
 Rule logic: IF sender is in 'Marketing Vendors' contact group
 THEN forward a copy to b.foster.home@examplemail.com
 Detail : Rule created during business hours from the user's own workstation.
 No attempt to hide the rule. User has not been contacted.

MTB-C05 DISPLAY NAME IMPERSONATION Wed 06:12 EDT Severity: Medium
 From : diane.kessler.cfo@examplemail.com
 Display : 'Diane Kessler'
 To : 1 recipient (Accounts Payable shared mailbox)
 Subject : Quick favour - are you at your desk?
 Detail : No links, no attachments. Generic text. Classic gift-card pretext.
 Gateway : QUARANTINED before delivery. Recipient never saw it.
 Reported independently by a second employee who received a
 similar message at a previous employer.

6.4 Suspicious wire transfer alerts

MTB-D01 NEW BENEFICIARY, HIGH VALUE Tue 23:12 EDT Severity: High
 Initiated : tokafor
 Amount : 47,500.00 USD
 Beneficiary: Sorana Trading SRL
 Bank : Banca Transilvania, Romania
 Detail : Beneficiary added to the payee list at 23:06 the same evening.
 First payment to this beneficiary. Initiated 6 hours after the
 17:00 wire cut-off. Dual approval: NOT YET OBTAINED, queued.

MTB-D02 RECURRING HIGH VALUE Tue 09:30 EDT Severity: Low
 Initiated : tokafor

Amount : 129,880.00 USD
 Beneficiary: ADP Payroll Services
 Bank : Wells Fargo, US
 Detail : Fortnightly payroll run. Amount within the normal range for this beneficiary. Dual approval obtained from Treasury lead.

MTB-D03 THRESHOLD PATTERN Tue 11:02 - 16:40 Severity: Medium
 Initiated : rharper (Accounts Payable)
 Detail : 5 outbound transfers in one day, all to different beneficiaries, none previously used:
 11:02 9,850.00 USD 13:15 9,700.00 USD
 14:28 9,900.00 USD 15:51 9,750.00 USD
 16:40 9,800.00 USD
 Total 49,000.00 USD. No single transfer reached the 25,000 USD dual-approval threshold, so none required a second approver.

MTB-D04 BENEFICIARY DETAILS CHANGED Mon 15:20 EDT Severity: High
 Beneficiary: Castlereagh Supply Co
 Changed by : rharper (Accounts Payable)
 Detail : Account number and receiving bank changed from PNC Bank US to an account at a different institution. Change requested by an email from the vendor's accounts contact. No callback to a previously known telephone number was recorded.
 Scheduled payment of 88,400.00 USD due Thursday.

MTB-D05 HIGH VALUE Tue 14:05 EDT Severity: Low
 Initiated : tokafor
 Amount : 250,000.00 USD
 Beneficiary: Harrow Logistics Ltd
 Bank : Barclays, UK
 Detail : Established beneficiary. Amount at the top of its normal range but within it. Approval reference CR-2291 recorded. Dual approval obtained from the CFO and the Treasury lead.

See Spreadsheet for 6.5 triaged alert queue:

<https://docs.google.com/spreadsheets/d/1fMAiUXEXKH84PMqFtpRIq9p2Xs5sLFEtDBG5v85zFuA/edit?usp=sharing>

6.5 Step by step

1. Read Sections 4 and 5 before you touch the queue. Most wrong answers on this lab come from skipping the reference data.
2. Work each alert. Identify the type, apply the runbook, decide CLOSE or ESCALATE, and record your justification and confidence.
3. Do the arithmetic on every impossible-travel alert yourself. Do not take the alert's word for it, and do not take the word 'impossible' in the alert title as a finding.
4. Check every address in the queue against Section 4.3 before you treat it as external.
5. Fill in the Linked alerts column as you go. When you have finished all twenty, sort your log by account name and look again.

6. Count your escalations. If you escalated more than about half the queue, re-read the ones you are least sure about. If you escalated fewer than five, do the same.

12 alerts were escalated. This is more than half but they include 2 noted ambiguous alerts.

7. Identify the two alerts you found genuinely ambiguous, and write a paragraph on each explaining what would settle it and who you would ask.

MTB-B05 (Sarah Grigsby Impossible Travel)

I escalated B05 with medium confidence. The 224-mile Pittsburgh to Toronto movement in 95 minutes cannot reasonably be explained by driving, and there is no travel request in the system. That supports escalation under the Impossible Travel runbook. However, the alert itself states that Audit travel is “booked departmentally and is not always recorded centrally”, so the lack of a travel record is not strong evidence that Grigsby was not traveling. Her post-login activity, accessing the internal audit workpaper repository, is also consistent with her job. What would settle the alert is confirmation that Audit booked travel to Toronto for her and verification that the second authentication originated from the device she normally uses. I would ask the Audit administration or the employee's manager to confirm the travel.

MTB-C05 (CFO Business Email Compromise)

I escalated C05 with medium confidence but there is a conflicting case for closure at the tier 1 level. Evidence for closure is the gateway quarantined the message before delivery, nobody acted on it, there were no links or attachments, and the content was generic. This fits one of the BEC closure conditions, however, another condition says to escalate when an executive is impersonated or an authorized payment function is targeted, and this message uses the CFO's identity against Accounts Payable. What would help settle the risk is checking whether there are other messages from the same or similar impersonation attempts, especially any that escaped quarantine or targeted executives. I would forward this to the tier 2 team to search the mail environment for related sender addresses, display names, subjects, and recipients.

One account appears in more than one category

Sort your triage log by account name before you call the queue finished. That single step is the difference between twenty individual alerts and one incident.

7. Day 1: Writing Escalation Notes

Everything you escalate needs a note. The note is the entire handover. Tier 2 will act on what you wrote, not on what you meant, and on a busy shift they will not come and ask you.

7.1 The format

Field	What goes in it
Alert ID and type	Which alert, and what kind
What was observed	The facts only. Accounts, addresses, times, amounts. No interpretation yet.
Why it is suspicious	Your reasoning, and the runbook criterion you applied
What Tier 2 should look at first	The single most useful next step. Be specific.

Field	What goes in it
Related alerts	Any other alert ID you think belongs with this one
Urgency	Your assessment, and why. Money in motion beats everything else.

7.2 A worked escalation note

ALERT : MTB-A02, failed login threshold

OBSERVED : 1,284 authentication failures against the external webmail portal between 23:18 and 23:29 Tuesday, from 45.134.26.91, spread across 312 distinct accounts at 3 to 5 attempts each. No successes.

SUSPICIOUS : The low per-account attempt count combined with the very high account count is the signature of password spraying rather than brute force. The attempt count per account sits deliberately below our lockout threshold. Failed Login Runbook escalation criterion 1.

FIRST STEP : Confirm whether any of the 312 accounts authenticated successfully from any source in the following 24 hours. The absence of success during the spray does not mean the attacker learned nothing.

RELATED : None identified.

URGENCY : Medium. No confirmed compromise, but the source is still active and the account list suggests prior enumeration of our directory.

What makes that note useful

It separates what was seen from what it means, so Tier 2 can disagree with the interpretation without having to re-derive the facts.

The first step is a specific question with a yes or no answer, not 'investigate further'.

It names the runbook criterion, so the decision can be reviewed against procedure months later.

It says what the absence of evidence does not prove. That sentence is what separates a Tier 1 analyst from a ticket forwarder.

7.3 Step by step

1. Write a note in the Section 7.1 format for every alert you escalated.
2. For your highest-urgency escalation, write the first step as a question that can be answered yes or no.
3. For every alert you closed, write one or two sentences of justification in your triage log. A closure with no reasoning is itself a finding your shift lead will raise.

See Spreadsheet above for closure notes

4. Pick the three closures you are least confident about and add a sentence to each saying what would change your mind.

Escalation Notes

ALERT: MTB-A02, failed login threshold

OBSERVED: 1,284 authentication failures occurred against the external webmail portal between approximately 23:18 and 23:29 Tuesday from external address 45.134.26.91. The attempts affected 312 distinct accounts, with only three to five attempts against each account. No successes were recorded during the alert window.

SUSPICIOUS: The very high number of accounts combined with a deliberately low number of attempts per account is consistent with password spraying. This meets the Failed Login runbook criterion for failures spread across many accounts from one source.

FIRST STEP: Determine whether any of the 312 targeted accounts successfully authenticated from a new or unusual source in the following 24 hours.

RELATED: None identified in the current queue.

URGENCY: Medium. There is no confirmed successful authentication, but the breadth of account targeting suggests an organized credential attack.

ALERT: MTB-A04, privileged-account failed login/success

OBSERVED: Domain administrator dkoenig had nine failures between 23:47 and 23:51 Tuesday from 10.50.1.77, followed by a successful authentication. MFA succeeded on the fourth push. Koenig's assigned workstation is 10.50.1.52, and he is on approved leave all week.

SUSPICIOUS: This is a privileged account successfully authenticating late at night from a workstation that is not the user's assigned system while the user is known to be away. Multiple MFA prompts further increase suspicion.

FIRST STEP: Confirm whether Daniel Koenig was responsible for the successful 23:51 login using a known out-of-band contact method.

RELATED: None identified.

URGENCY: High. A successful domain-administrator compromise could give an attacker broad access even if no additional queue alerts have yet fired.

ALERT: MTB-B01, impossible travel

OBSERVED: rpatel authenticated from Pittsburgh and then Lagos with only 47 minutes available between the locations. The distance is 5,578 miles, requiring approximately 7,121 mph. MFA succeeded on the sixth push.

SUSPICIOUS: The required speed is physically impossible and greatly exceeds the runbook's 600 mph escalation threshold. Repeated MFA prompting also raises concern about unauthorized access.

FIRST STEP: Determine whether the Lagos session came from a device, browser, or session token previously associated with Patel.

RELATED: None identified.

URGENCY: High. A successful foreign authentication occurred despite impossible travel.

ALERT: MTB-B04, impossible travel

OBSERVED: tokafor authenticated from Pittsburgh at 21:50 and Bucharest at 22:58, requiring approximately 4,410 mph. MFA succeeded only on the ninth push. At 23:04, the Bucharest session accessed the wire-transfer initiation system.

SUSPICIOUS: The movement is physically impossible, and sensitive financial-system access occurred immediately after the second authentication. The source address also appears in C01.

FIRST STEP: Determine whether the Bucharest authentication created the session used to access the wire-transfer system at 23:04.

RELATED: MTB-C02, MTB-C01, MTB-D01.

URGENCY: Critical / highest priority. This authentication is directly connected to activity involving a pending financial transfer.

ALERT: MTB-B05, impossible travel

OBSERVED: sgrigsby authenticated in Pittsburgh at 07:40 and Toronto at 09:15. The 224-mile movement in 95 minutes implies approximately 141 mph. No central travel request exists, although Audit travel is not always centrally recorded.

SUSPICIOUS: Normal ground travel does not explain the timing, and Tier 1 lacks confirmed travel information. However, the employee's job activity after login was plausible, making this an ambiguous case.

FIRST STEP: Confirm whether Audit had departmental travel booked for Sara Grigsby in Toronto that morning.

RELATED: None.

URGENCY: Medium. The login is unexplained, but no clearly malicious post-login behavior is documented.

ALERT: MTB-C01, BEC mailbox rule

OBSERVED: At 23:09, a rule named .. was created in tokafor's mailbox from 89.36.216.140. It matches financial terms including wire, invoice, payment, beneficiary, confirm, and approval, then moves matching messages to RSS Subscriptions and marks them read.

SUSPICIOUS: The rule is specifically designed to hide financial correspondence and meets the BEC runbook's strongest mailbox-rule escalation condition. Its source matches B04's Bucharest authentication.

FIRST STEP: Determine whether any financial messages have already been moved or hidden by this rule and whether any relate to newly initiated payments.

RELATED: MTB-C02, MTB-B04, MTB-D01.

URGENCY: Critical. The rule could conceal questions or warnings concerning a fraudulent payment.

ALERT: MTB-C02, BEC lookalike domain

OBSERVED: t.okafor@meridian-trust.com sent a message to tokafor@meridiantrust.com. The sender domain was registered nine days earlier, failed SPF, had no DKIM or DMARC, and linked to a credential-entry page styled as Meridian's Treasury portal. The gateway delivered the message.

SUSPICIOUS: The sender uses a lookalike domain that differs from the legitimate domain by a hyphen and directs a Treasury user to a credential-entry page. Lookalike domains require escalation under the BEC runbook.

FIRST STEP: Determine whether Okafor's workstation accessed the credential-entry URL after the message was delivered.

RELATED: MTB-B04, MTB-C01, MTB-D01.

URGENCY: High. This may represent the initial credential-theft stage of the linked Treasury incident.

ALERT: MTB-C04, BEC external forwarding

OBSERVED: Brian Foster created a rule named "Copy to personal" during business hours from his assigned workstation. It forwards messages from Marketing Vendors to b.foster.home@examplemail.com.

SUSPICIOUS: The circumstances look user-initiated, but the rule forwards bank email to an external personal account, which is an explicit runbook escalation criterion.

FIRST STEP: Confirm whether Foster intentionally created the rule and whether external forwarding is authorized by bank policy.

RELATED: None.

URGENCY: Medium-Low. There is no evidence of concealment or account takeover, but potential data leakage must be validated.

ALERT: MTB-C05, CFO impersonation

OBSERVED: An external address displayed the name "Diane Kessler" and sent a generic gift-card style message to the Accounts Payable shared mailbox. The message contained no links or attachments and was quarantined before delivery.

SUSPICIOUS: Although no recipient saw the email, it deliberately impersonates Meridian's CFO and targets a financial function. Executive impersonation is an escalation criterion.

FIRST STEP: Determine whether any similar CFO-impersonation messages from the same campaign were delivered to other Meridian employees.

RELATED: No confirmed linkage.

URGENCY: Medium-Low. This specific message was contained, but campaign scope is unknown.

ALERT: MTB-D01, suspicious wire transfer

OBSERVED: tokafor added Sorana Trading SRL in Romania at 23:06 and initiated a \$47,500 first payment at 23:12, six hours after Meridian's 17:00 wire cutoff. Dual approval has not yet been obtained.

SUSPICIOUS: The beneficiary is new, the first payment is significant, the activity happened outside business hours, and the initiating account is simultaneously involved in impossible-travel and BEC alerts.

FIRST STEP: Has the \$47,500 transfer been approved or released from the pending queue?

RELATED: MTB-C02, MTB-B04, MTB-C01.

URGENCY: Critical. Money is potentially still in motion. This should be the highest-priority Tier 2 handoff.